THREAT & RISK + RISK MATRIX

Lanza P3 Panel Sizing Machine

ÇIKTI
Risk Register
Evidence Pack: EP 04
Cyber Risk Assessment

Makine	Lanza P3 Panel Sizing Machine	**Üretici**	Ayza Mızrak Makine San. ve Tic. Ltd. Şti.
Ad Soyad	Zeliha Sena Güllü	**Grup / Numara**	Gece/B 235541048

YÖNTEM: Senaryo = profil → giriş kapısı → eylem → zincir → FİZİKSEL sonuç. Skor = L × S × E; her puan 1–3. S=3 olan her senaryo, skoru düşük olsa bile ayrıca görünür tutulur.

KANIT SINIRI: Ürün kaydı internet üzerinden uzaktan erişim, TPA CNC, ARDIS optimizasyon yazılımı ve barkod sistemini belirtiyor. Protokol, doğrudan internet maruziyeti, kimlik doğrulama, ağ topolojisi ve gerçek emniyet devresi bilinmiyor. Puanlar ön değerlendirmedir, denetim sonucu değildir.

Safety 4.0 Risk Matrix | Puanlama ölçeği

Ölçüt	1	2	3
L · İstismar edilebilirlik	Zor; çoklu koşul veya özel erişim	Orta; erişim ya da zayıf kontrol gerekir	Kolay; doğrulama zayıf / hazır istismar
S · Fiziksel şiddet	Fiziksel yaralanma beklenmez	Hafif, geri dönüşlü yaralanma	Ağır/kalıcı yaralanma veya ölüm
E · Maruziyet	Yerinde fiziksel erişimle sınırlı	Kontrollü veya sınırlı ağ/uzak erişim	Doğrudan veya sürekli dışa açık yol

Bantlar: Kritik 18–27 | Yüksek 9–17 | Orta 4–8 | Düşük 1–3. S, siber etkinin değil, fiziksel sonucun şiddetidir.

Risk Register | İlk sıralama

ID	Profil / kapı	Fiziksel sonuç senaryosu	L	S	E	Skor / karar
R-01	Fırsatçı dış / internet üzerinden uzaktan erişim	Yetkisiz CNC program/ayar müdahalesi mümkünse tehlikeli kesim hareketi ve ağır kesilme riski doğabilir.	2	3	2	**12 · YÜKSEK S3**
R-02	Yetkisini aşan içeriden / yerel program erişimi	Kesim programı veya ayarı değişir ve operatör müdahale sırasında tehlikeli harekete maruz kalırsa ağır yaralanma olabilir.	2	3	1	**6 · ORTA S3**
R-03	Tedarik zinciri / servis güncellemesi (koşullu)	Değiştirilmiş yazılım/ayar makineye aktarılırsa beklenmeyen hareket ve ağır yaralanma riski olabilir.	1	3	1	**3 · DÜŞÜK* S3**

KOŞULLU PUAN: R-03 için L1/E1, yalnızca servis veya güncelleme yolunun yerel ve kontrollü olduğu varsayımına dayanır. Bu yol doğrulanmadığından gerçek mevcut risk puanı değildir.

01 En yüksek öncelikli senaryo hangisi, neden?

R-01 ilk inceleme önceliğidir: internet üzerinden uzaktan erişim ürün kaydında belirtilmiştir ve yetkileri CNC davranışını etkileyebiliyorsa ağır fiziksel sonuca bağlanabilir. 12 puan Yüksek ve S3 bayraklıdır. Doğrudan internet açıklığı veya bilinen bir açık kanıtlanmış değildir.

02 S=3 olup skoru düşük kalan senaryo var mı? Nasıl görünür kılınır?

Evet, R-03 koşullu örnektir: L1 × S3 × E1 = 3. “S3” bayrağıyla ayrı listelenmeli, varlık sahibine gösterilmeli ve kanıtla yeniden puanlanmalıdır. Önlem veya belgelenmiş risk kabul kararı olmadan kapatılmamalıdır.

Risk Register | Ayrıntılı kayıtlar

Aşağıdaki puanlar mevcut sistemde kanıtlanmış zafiyetleri değil, belirsizlikler açıkça belirtilerek oluşturulmuş başlangıç senaryolarını gösterir.

R-01 | 12 · L2 × S3 × E2 · YÜKSEK / S3 | Uzaktan erişimin kötüye kullanılması	
Profil / kapı	Fırsatçı dış saldırgan. Kapı: ürün sayfasında belirtilen internet üzerinden uzaktan erişim. Doğrudan internete açık olduğu doğrulanmadı.
Beş parçalı senaryo	Saldırgan uzaktan erişimi ele geçirir ve verilen yetkiler izin verirse CNC programı/ayarını değiştirmeye çalışır; kesim hareketi değişir ve operatör tehlikeli bölgeye maruz kalır.
Etkilenen işlev / fiziksel sonuç	Hedef: tehlikeli kesim hareketinin güvenli biçimde durması ve operatörün kesiciye erişmesinin önlenmesi. Gerçek emniyet işlevleri şemayla doğrulanmalı. Olası sonuç: ağır kesilme/uzuv kaybı.
L · S · E gerekçesi	L=2: protokol ve doğrulama bilinmiyor; kolay istismar kanıtı yok. S=3: dairesel testere ağır yaralanmaya yol açabilir. E=2: uzaktan erişim var, doğrudan maruziyet belirsiz.
Kontroller / eylem / kanıt	Mevcut durum: Makineye özel erişim kuralları, kimlik doğrulama ve ağ topolojisi kamuya açık kaynaklarda doğrulanamadı. Öneri: Doğrudan açık port bırakmama; VPN+MFA+jump server; kişisel hesap, en az yetki; varsayılan kapalı/süre sınırlı erişim; oturum ve komut kaydı; emniyet yolundan ayrım. Sahip ve kanıt: Sahip: OT/IT güvenlik sorumlusu (öneri). Kanıt: ürün sayfası [K1]; protokol/topoloji/yetkiler için kanıt eksik.

R-02 | 6 · L2 × S3 × E1 · ORTA / S3 | Yerel program veya parametre değişikliği	
Profil / kapı	Yetkisini aşan çalışan/yüklenici. Kapı: operatör yazılımı veya kesim listesine yerel erişim. Kullanıcı rolleri doğrulanmadı.
Beş parçalı senaryo	Kullanıcı yetkisini aşarak kesim programını veya ayarları değiştirirse çalışma sırası beklenenden farklı olabilir; müdahale sırasında beklenmedik hareket oluşursa operatör zarar görebilir.
Etkilenen işlev / fiziksel sonuç	Hedef: tehlikeli harekete erişimi önlemek ve tehlikeli durumda hareketi güvenli şekilde durdurmak. Değişikliğin emniyet sistemine etkisi henüz doğrulanmadı. Olası sonuç: ağır kesilme veya sıkışma.
L · S · E gerekçesi	L=2: yerel arayüz ve ayar erişimi senaryo varsayımı; hesap/rol kontrolleri bilinmiyor. S=3: ağır fiziksel sonuç mümkün. E=1: yerinde fiziksel erişim varsayılmıştır.
Kontroller / eylem / kanıt	Mevcut durum: Ürün sayfası operatör yazılımı ve manuel/otomatik kesim seçeneklerini belirtiyor; kullanıcı yetkileri ve erişim kayıtları bilinmiyor. Öneri: Kişisel hesap ve rol bazlı yetki; program değişiklik kaydı/onayı; onaylı program kopyası; temizlik/sıkışma giderme öncesi güvenli durdurma prosedürü. Sahip ve kanıt: Sahip: üretim sorumlusu + kontrol mühendisi (öneri). Kanıt: [K1]; yetki ve emniyet bağlantısı için ek belge gerekir.

R-03 | 3 · L1 × S3 × E1 · DÜŞÜK* / S3 | Tedarik zinciri / servis güncellemesi (koşullu)	
Profil / kapı	Tedarik zinciri saldırganı. Kapı: servis bilgisayarı, yazılım paketi veya güncelleme yolu; Lanza P3 için dağıtım yöntemi doğrulanmadı.
Beş parçalı senaryo	Koşullu senaryo: yazılım/program paketi servis kanalında değiştirilip makineye aktarılırsa kontrol davranışı veya kesim verisi bozulabilir; tehlikeli hareket sırasında yaralanma doğabilir.
Etkilenen işlev / fiziksel sonuç	Hedef: normal kontrol yazılımındaki değişikliğin emniyet işlevini devre dışı bırakamaması. Gerçek mimari bilinmiyor. Olası sonuç: ağır yaralanma.
L · S · E gerekçesi	L=1 ve E=1 yalnızca güncelleme yolunun özel, yerel ve kontrollü olduğu varsayımıyla verilmiştir. S=3 çünkü olası fiziksel sonuç ağırdır. Varsayımlar doğrulanmadı.
Kontroller / eylem / kanıt	Mevcut durum: TPA/ARDIS yazılımları listeleniyor; güncelleme yöntemi, imza doğrulaması ve SBOM bilgisi doğrulanmadı. Öneri: İmzalı/doğrulanabilir paket; sürüm ve bütünlük kontrolü; yetkili servis erişimi; güncelleme öncesi yedek/değişiklik kaydı; güvenlik duyurularını izleme. Sahip ve kanıt: Sahip: üretici/servis + OT sorumlusu (öneri). Kanıt: [K1], [K3]; güncelleme yoluna özel kanıt eksik.

PUANLAMA DİSİPLİNİ: Her L/S/E değeri için bir cümlelik gerekçe yaz. Bilinmeyen kontroller varsa puanı geçici olarak işaretle ve gereken belgeyi eylem listesine ekle. Lanza P3 için R-01–R-03 puanları ürünün mevcut güvenlik seviyesini kesin olarak ölçmez.

Ek Değerlendirme ve Tartışma Soruları

Bu sayfa, öğretmenin paylaştığı beş tartışma sorusunun cevaplarını ve çalışmayı derinleştirmek için eklenen üç soruyu içerir. Ana Risk Register'ın yerine geçmez.

1. Aynı kapıyı iki farklı profil kullanabiliyorsa skor değişir mi?	Evet, özellikle L değişebilir; saldırganın yeteneği ve ilk erişim olasılığı farklıdır. Aynı kapı aynı maruziyeti, aynı emniyet işlevi ve fiziksel sonuç aynı S değerini destekleyebilir. Zincir veya gerekçe farklıysa ayrı kayıt açılır; yalnızca profil adı değişti diye aynı senaryo çoğaltılmaz.
2. Skoru 27 olan S=1 ile skoru 3 olan S=3 senaryodan hangisi önce ele alınır?	S=3 senaryosu için ağır fiziksel zarara giden yolu kontrol altına alacak önlem veya geçici telafi geciktirilmemelidir. 27 puanlı S=1 senaryosu da ciddi siber/üretim riskidir ve planlanmalıdır. S3 bayrağı, yüksek şiddetin çarpım içinde kaybolmasını önler.
3. Emniyet fonksiyonuna dokunmayan siber senaryo bu Register'a girmeli mi?	Fiziksel zarara uzanan makul bir zincir yoksa emniyet riski olarak bu kayda konmamalı; ayrı bir siber/iş sürekliliği kaydı uygun olabilir. Ancak üretim kesintisi operatörü korumayı devre dışı bırakmaya veya makine çalışırken sıkışmayı gidermeye zorluyorsa dolaylı fiziksel zincir araştırılmalıdır.
4. Tedarikçinin "sistemimiz güvenli" beyanına ne kadar güvenilir?	Beyan tek başına kanıt değildir. Makine ve yazılım sürümüyle eşleşen ağ topolojisi, uzaktan erişim protokolü/yetkileri, MFA ve hesap politikası, oturum kayıtları, elektrik/emniyet devresi şeması, güncelleme yöntemi, zafiyet bildirim süreci ve varsa SBOM/test belgeleri istenmelidir.
5. Risk Register ne zaman yeniden puanlanmalı?	CNC/operatör yazılımı veya firmware güncellemesi; uzak erişim, ağ topolojisi veya kullanıcı yetkisi değişikliği; yeni CVE/istismar duyurusu; tedarikçi ya da servis süreci değişikliği; yeni üretim iş akışı; kaza, ramak kala, şüpheli bağlantı veya emniyet bileşeni değişikliği sonrasında ve düzenli aralıklarla.
6. Belirsizliği en çok azaltacak üç kanıt hangisi?	(1) Uzaktan erişim mimarisi: protokol, bağlantı yönü, kimlik doğrulama, rol/yetki ve internete erişilebilirlik. (2) Lanza P3'e ait elektrik/emniyet devresi ve risk değerlendirmesi. (3) Kurulu TPA CNC/operatör ve ARDIS sürümleri, barkod veri akışı ve güncelleme yöntemi.
7. VPN ve MFA uygulanırsa L, S, E'den hangileri değişir?	VPN, MFA, jump server, kişisel hesap ve varsayılan kapalı erişim, istismar olasılığını ve/veya maruziyeti azaltarak L ve E'yi düşürebilir. Testere bıçağının verebileceği fiziksel zararın şiddeti S değişmez. S ancak emniyet işleviyle siber yol arasındaki etki zinciri bağımsız ve doğrulanmış tasarımla kesilirse yeniden değerlendirilebilir.
8. Mevcut, hedef ve artık risk nasıl ayrılır?	Mevcut risk bugünkü kurulum ve doğrulanmış kontrollerle puanlanır. Hedef risk, önerilen kontroller uygulanırsa beklenen düzeydir. Artık risk, kontroller gerçekten uygulanıp test edildikten sonra kalan risktir. Lanza P3'ün mevcut erişim kontrolleri bilinmediğinden gerçek artık risk puanı veremiyoruz.

Kaynakça ve doğrulama sınırı

[K1] TWM / AİMSAD, Lanza P3 ürün sayfası: https://new.twm.com.tr/en/product/lanza-p3-panel-sizing-machine
[K2] Ser & Bir Makine, Lanza P3 ürün kaydı: https://www.serbirmakina.com/tr/urunler/lanza-p3-4911
[K3] TPA, Eye On Machine (ürünün genel açıklaması; Lanza P3'e kurulu olduğu doğrulanmadı): https://www.tpaspa.com/eye-on-machine
[K4] IEC 62443-3-2, endüstriyel otomasyon sistemleri için güvenlik risk değerlendirmesi: https://webstore.iec.ch/en/publication/30727

BELİRSİZLİK NOTU: Lanza P3'e özel elektrik/emniyet şeması, uzaktan erişim protokolü, kurulu yazılım sürümleri ve gerçek ağ topolojisi kamuya açık kaynaklarda doğrulanmadı. Senaryolar eğitim amaçlı ön değerlendirmedir; bilinen bir zafiyetin ya da denetim sonucunun beyanı değildir.